

Stellarus Security Questionnaire

R-02 Validate prompt injection controls in Sierra

Sierra owns the guardrails and prompt defense controls. BSC cannot directly inspect or modify them today, which creates a risk that prompt injection could bypass topic restrictions or expose out-of-scope information.

Key remediation:

- Confirm contractual right to review and approve system prompt and guardrail configuration
 - *BSC/Stellarus own and control their agent's system prompt and guardrail configuration in Agent Studio, with full rights to review and approve it. This applies to the customer's own agent configuration rather than Sierra's underlying platform settings.*
- Obtain evidence of guardrail test results
 - *Sierra publishes red-team and guardrail testing results on our security page, and we can share these as supporting evidence as needed*
- Add document integrity checks on ingest into the RAG store
 - *[need clarification] Currently the document we have in the KB (official FEP brochures)*
- Require version control and notification for prompt changes
 - *Yes. Sierra SDK releases are version-controlled and accompanied by release notes, so changes to prompts and guardrail configuration are both tracked and communicated as part of the standard release process.*
- Include prompt injection attack cases in staging QA
 - *Yes. Our simulation-based QA already includes prompt injection test cases. We can also expand coverage with additional simulations if BSC would like broader or scenario-specific testing.*

R-03 Verify dataset isolation for non-PHI pilot data

The pilot depends on Sierra keeping the dedicated non-PHI benefits dataset fully isolated from other data stores, including PHI-bearing datasets. Misrouting or retrieval bleed would create a major disclosure risk.

Key remediation:

- Obtain written technical evidence of dataset isolation
 - *Customer data is stored in a multi-tenant architecture database. Customer data is logically segregated from other customers and is stored in AWS DynamoDB and AWS S3. Sierra uses AWS, which provides logical segregation of the customer data. We have strong checks to ensure logical segregation.*

- *[See Sierra Network Diagram attached]*
- Customer Data Access
 - *All tenant data is logically segregated and controlled by strict access control. Sierra enforces role-based access control (RBAC) and the principle of least privilege, ensuring that personnel have access only to necessary programs and data to perform their duties. Access to customer data would only be granted to those with a bona fide need or under the direction of the customer. Access reviews are performed quarterly.*
 - *The customer controls which customer materials and customer data are processed by Sierra. As part of the implementation, Sierra will integrate with the customer's systems via secure APIs. In addition, the customer may provide the team implementing the agent with confidential materials that may describe the customer's business processes or other material that may be helpful for defining the agent's behavior.*
- Require a dedicated QA demonstration before pilot launch
 - *[confirming question with Stellarus]*
- Test with prompts designed to elicit PHI or cross-dataset retrieval
 - *The current pilot does not retrieve PHI. Once we integrate the new eligibility and claims APIs, we can run tests using prompts specifically designed to elicit PHI or cross-dataset retrieval. It is worth noting that the data surface here is governed by the upstream APIs: our agent can only retrieve what those APIs return, so the scope of any potential PHI exposure is shared with the API design on the BSC and Stellarus side.*
- Add dataset isolation verification to QA acceptance criteria and Definition of Done
 - *[confirming question with Stellarus]*
- Require notification of platform changes affecting multi-tenancy or dataset routing
 - *We will notify the customer in advance of major changes that could impact the application or services being provided. This would be part of the customer notification SLA and commitments, and in alignment with our incidence response program.*

R-07 Establish response provenance for auditability

Sierra owns inference. BSC cannot independently verify what the model was given, what documents were retrieved, or which model version produced a response. Without a BSC-accessible provenance log, accuracy failures cannot be investigated, the ≥95% KPI cannot be verified, and there is no audit trail for regulatory review.

Recommendations:

1. Confirm the BAA includes BSC right to access response provenance logs

[Sierra to provide BAA template]

2. Require a provenance record per response: model version, system prompt hash, retrieval document IDs, and timestamp

All security- and privacy-related actions taken within Agent Studio (e.g., user permission edits and PII configuration changes) can be logged and forwarded into the customer's own audit trail systems. Audit log events are generated for key security and privacy-related actions, and Agent Studio integrates with WorkOS to allow customers to export these log events to their designated systems or SIEM platforms.

More information here:

<https://team.sierra.ai/documentation/access-and-security/audit-logs>

3. Provenance logs must be exportable to BSC-controlled storage

Yes. Provenance logs are not confined to Sierra's infrastructure. They can be exported to BSC-controlled storage through our export API.

4. Wire accuracy KPI measurement to the provenance log, not to self-reported Sierra metrics

[confirming question with Stellarus]

5. When Sierra changes or adds new models, how are we alerted, how does testing work across each model?

You will be notified ahead of any model change or addition. Sierra performs rigorous internal testing before rolling out a new model, and we typically run a controlled test and gradual ramp prior to full deployment, so model behavior can be validated at each stage before it reaches production.